Roles and Permissions

Kestrelway Field Services gives every person who uses the fleet tools one of four roles. This document sets out what each role may do, why the rules sit where they do, and how approvals and the audit log fit in.

The four roles

Viewer. Reads everything: the asset list, device status, session insights, driver events, driver scores and inbox counts. A viewer runs no command at all.

Operator. Does everything a viewer does and may also run an OBD scan. An operator may not reboot a device, change a driving rule or run any of the irreversible commands.

Admin. Does everything an operator does, plus reboot a device, change driving rules, power off a device, clear a device's SMS inbox, purge a device's data and redeliver failed webhook deliveries.

Owner. Everything an admin may do. Only the owner may delete the organisation.

The permission matrix

Action	Viewer	Operator	Admin	Owner
Read status, insights, events, scores, inbox counts	yes	yes	yes	yes
OBD scan	no	yes	yes	yes
Reboot	no	no	yes	yes
Change a driving rule	no	no	yes	yes
Power off, clear SMS, purge	no	no	yes (with approval)	yes (with approval)
Redeliver webhooks	no	no	yes	yes
Delete the organisation	no	no	no	yes

Why Kestrelway takes the stricter side

The fleet app and the device platform did not agree. The fleet app let operators reboot and power off a device. The device platform does not: it reserves those commands for admins and owners. Where two systems disagree, Kestrelway takes the stricter side, so the platform's rule is the one that applies. A reboot interrupts telemetry for about 90 s, and a power-off cannot be undone remotely, so keeping both away from operators costs little and avoids mistakes.

Commands that always need approval

Three commands wait for a human decision whoever asks, even an owner:

- `power_off_device`: not remotely recoverable, because someone must restore power at the vehicle.
- `clear_sms`: deletes every message on the modem and cannot be undone.
- `purge_device`: permanently deletes workflow runs, telemetry and media.

The approver is the fleet lead on duty. The request stays pending until the lead decides, and the assistant never says the command ran before a tool result says it was queued or accepted.

The audit log

Every command decision is written to the audit log: who asked, which tool, which asset, the arguments, whether policy allowed, denied or sent it to approval, and what the approver decided. For the destructive commands the log also records the state of the device before the change, so a reviewer can see what was lost. Denials are logged too, so a refused request leaves a trace.

In the dev console

In the harness's dev console, the user acts as an admin. That means reads and admin commands are allowed by the role check, and the three always-approval commands still stop at the approval gate. A viewer's or operator's request for a reboot is denied by the policy rule before any human is asked.